

SecureShare — Use Case Specifications

Comprehensive IEEE 29148 Use Case Specification Suite (UC-01 to UC-12)

Standard: IEEE 29148 | Version: 1.0.0 | Date: October 2026
Authors: Sushmitha Reddy, Rahul Kumar, Priya Sharma, Arjun Rao

UC-01: User Registration & Argon2id Password Setup

Attribute	Specification Details
Primary Actor	Unregistered User
Preconditions	User does not have an active account.
Trigger	User navigates to /register and submits email, strong password, and full name.
Main Flow	1. Client validates password complexity (>= 10 chars, uppercase, digit, symbol). 2. Backend receives POST /api/v1/auth/register. 3. Password is hashed using Argon2id with unique 16-byte cryptographic salt. 4. User record is persisted with role=USER, is_active=True, failed_logins=0. 5. Audit log entry is appended to tamper-evident blockchain ledger. 6. JWT access token is generated and returned to client.
Exceptions	Password complexity failure -> HTTP 422 returned with specific violation list.
Postconditions	User account created, password stored securely as Argon2id hash, audit recorded.
Verification	SEC-TC-01, SEC-TC-02 (tests/security/test_authentication.py)

UC-02: Multi-Factor Authentication (TOTP) Setup & Verification

Attribute	Specification Details
Primary Actor	Authenticated User
Preconditions	User is logged in and possesses a TOTP authenticator application (Google/Microsoft Auth).
Trigger	User accesses /settings or /mfa-setup to activate two-factor authentication.
Main Flow	1. Backend generates RFC 6238 Base32 secret seed and otpauth:// URI. 2. Frontend renders QR code in secure browser canvas. 3. User scans QR code and enters 6-digit TOTP validation code. 4. Backend verifies code within +/- 30 second drift window. 5. mfa_enabled is set to True in database. 6. SHA-256 audit entry records MFA activation.
Exceptions	Invalid TOTP token -> HTTP 400 Bad Request; secret remains inactive.
Postconditions	Account requires TOTP code on subsequent login attempts.
Verification	SEC-TC-06, SEC-TC-07 (tests/security/test_authentication.py)

UC-03: Multi-Stage Secure File Upload

Attribute	Specification Details
Primary Actor	Authenticated User
Preconditions	User session authenticated via valid JWT bearer token.
Trigger	User drops a file onto /upload or triggers standard file selector dialog.
Main Flow	1. Frontend checks file size against 50MB ceiling. 2. File byte stream submitted via multipart/form-data to POST /api/v1/files/upload. 3. Backend sanitizes filename to eliminate directory traversal payloads. 4. Upload handed over to 6-Stage Threat Scanning Engine (UC-04). 5. Clean file encrypted via AES-256-GCM envelope service (UC-05). 6. File record inserted with sha256_hash and encrypted path. 7. Audit event logged with actor IP and file metadata.
Exceptions	File size > 50MB -> HTTP 413 Payload Too Large; upload aborted.
Postconditions	File stored safely on disk in encrypted format, visible in user file browser.
Verification	SEC-TC-04, SEC-TC-14, SEC-TC-15 (tests/security/test_file_upload.py)

UC-04: Automated Threat & Malware Scanning

Attribute	Specification Details
Primary Actor	Scanner Engine / Backend
Preconditions	Raw byte stream received by upload handler.
Trigger	Triggered automatically during upload pipeline processing.
Main Flow	1. Stage 1: File size verification (reject if > 50MB). 2. Stage 2: MIME magic byte analysis (libmagic) checks real payload format. 3. Stage 3: Executable & script header inspection (blocks PE, ELF, Bash, VBS). 4. Stage 4: Archive ratio & zip bomb recursive unpacking inspection. 5. Stage 5: ClamAV daemon antivirus signature detection (checks for malware & EICAR). 6. Stage 6: Shannon Entropy analysis calculates byte randomness (detects packed trojans). 7. Scanner marks file status: CLEAN or INFECTED.
Exceptions	Malicious signature detected -> File marked is_quarantined=True, moved to /quarantine (UC-11).
Postconditions	Only clean files proceed to encryption and storage; threats quarantined.
Verification	SEC-TC-12, SEC-TC-13 (tests/security/test_file_upload.py)

UC-05: AES-256-GCM Envelope Encryption

Attribute	Specification Details
Primary Actor	Crypto Service
Preconditions	Uploaded file payload verified clean by scanner engine.
Trigger	Triggered upon successful threat scanning completion.
Main Flow	1. CryptoService generates random 256-bit Data Encryption Key (DEK). 2. CryptoService generates cryptographically secure 96-bit unique IV (os.urandom(12)). 3. File plaintext encrypted using AES-256-GCM cipher. 4. 128-bit authentication tag appended to ciphertext. 5. DEK is wrapped using Master Encryption Key (MEK). 6. Wrapped payload written to /storage/uploads/{uuid}.enc. 7. Plaintext buffers securely zeroized in memory.
Exceptions	Cryptographic initialization failure -> Upload transaction rolled back; HTTP 500.
Postconditions	Zero plaintext stored on filesystem; files protected against disk exfiltration.
Verification	SEC-TC-17, SEC-TC-19 (tests/security/test_integrity.py)

UC-06: Authorized Decryption-on-the-Fly Download

Attribute	Specification Details
Primary Actor	Authenticated User / Guest
Preconditions	User requests file download and possesses valid access authorization.
Trigger	User clicks Download button on File Details or Public Share page.
Main Flow	1. API verifies user permission (Owner, Co-Owner, Downloader, or Token Bearer). 2. API confirms file is NOT in quarantine (if quarantined -> HTTP 403). 3. Encrypted ciphertext stream read from /storage/uploads. 4. AES-256-GCM authenticated cipher initialized with file-specific IV. 5. Payload decrypted in streaming memory buffer; GCM auth tag validated. 6. Content-Disposition and octet-stream headers emitted to client browser. 7. Audit log records successful download event.
Exceptions	Auth tag verification fails (tampered file) -> Decryption aborted; HTTP 500 tamper alert.
Postconditions	User receives original plaintext file; zero intermediate disk temp files created.
Verification	SEC-TC-08, SEC-TC-16, SEC-TC-18 (tests/security/test_file_download.py)

UC-07: Hierarchical Folder Management & BOLA Guard

Attribute	Specification Details
Primary Actor	Authenticated User
Preconditions	User session authenticated with valid JWT.
Trigger	User creates folder, moves file, or navigates folder tree.
Main Flow	1. User sends POST /api/v1/folders with name and optional parent_id. 2. Backend validates that parent_id belongs to current user_id (BOLA check). 3. Folder record created in folders table. 4. Folder tree rendered in UI with breadcrumb navigation. 5. User can move files into folder by updating folder_id.
Exceptions	User specifies parent_id belonging to another tenant -> HTTP 403 Forbidden.
Postconditions	Folder tree isolated per tenant with zero cross-tenant information leakage.
Verification	SEC-TC-08, SEC-TC-09 (tests/security/test_bola.py)

UC-08: Granular Permission Sharing (DAC)

Attribute	Specification Details
Primary Actor	File Owner
Preconditions	User owns target file and desires sharing access with a colleague.
Trigger	Owner navigates to /permissions/:fileId and enters colleague's email.
Main Flow	- Owner selects preset: VIEWER, DOWNLOADER, EDITOR, or CO_OWNER. - Backend resolves recipient user_id by email. - Permission entry inserted with specific boolean flags (can_read, can_download, etc.). - Colleague immediately sees file in their 'Shared with Me' view. - Revoke immediately deletes permission row, revoking access in real time.
Exceptions	Owner attempts sharing with non-existent email -> HTTP 404 User not found.
Postconditions	Recipient granted exact principle-of-least-privilege access rights.
Verification	SEC-TC-10, SEC-TC-11 (tests/security/test_permissions.py)

UC-09: Expiring Public Link Generation & Verification

Attribute	Specification Details
Primary Actor	File Owner / Recipient
Preconditions	User owns clean file and wants to generate an external share link.
Trigger	Owner clicks 'Create Public Share' and configures expiration date & password.
Main Flow	- Backend generates cryptographically secure 32-byte URL-safe token. - If password provided, password hashed via Argon2id. - Expiry timestamp and max_downloads counter persisted. - Recipient visits /share/{token}. - System verifies expiration and download count limits. - If password protected, prompts recipient for password before decryption download. - Download counter decremented; link deactivated when max reached.
Exceptions	Link accessed after expiration date -> HTTP 410 Gone / Link has expired.
Postconditions	Secure anonymous access provided within strictly bounded parameters.
Verification	SEC-TC-20, SEC-TC-21, SEC-TC-22 (tests/security/test_share_links.py)

UC-10: Tamper-Evident SHA-256 Audit Log Verification

Attribute	Specification Details
Primary Actor	Auditor / Admin
Preconditions	User possesses AUDITOR or ADMIN system role.
Trigger	Auditor navigates to /admin/audit-logs and clicks 'Verify Hash Chain'.
Main Flow	- Backend verifier retrieves all audit log rows ordered by sequence ID. - For each row: expected_hash = sha256(prev_hash + actor_id + action + timestamp). - Verifier compares calculated expected_hash against stored log_hash. - If all rows match: returns is_valid=True, total_verified=N, tampered_index=None. - If row tampered: returns is_valid=False with exact row ID and discrepancy details. - Audit verification report rendered in SOC dashboard.
Exceptions	Manual DB row modification detected -> Verification fails; critical SOC alert raised.
Postconditions	Audit ledger provides cryptographic proof of non-repudiation and integrity.
Verification	SEC-TC-24, SEC-TC-25 (tests/security/test_audit_logging.py)

UC-11: SOC Admin Quarantine Management & Purge

Attribute	Specification Details
Primary Actor	System Admin
Preconditions	Admin authenticated with ADMIN role; threats exist in quarantine.
Trigger	Admin navigates to /admin/quarantine to inspect flagged malware files.
Main Flow	1. Admin reviews threat details: malware signature, scanner stage, upload timestamp. 2. Admin reviews actor IP and uploader account. 3. Admin can release false positives: moves file from /quarantine to /uploads. 4. Admin can permanently purge threats: physically unlinks file from disk and database. 5. Action recorded in audit blockchain.
Exceptions	Regular user attempts quarantine release/purge -> HTTP 403 Forbidden.
Postconditions	Malicious payloads contained or destroyed; system protected against infections.
Verification	SEC-TC-11, SEC-TC-16 (tests/security/test_role_escalation.py)

UC-12: CI/CD DevSecOps Security Gate Pipeline Execution

Attribute	Specification Details
Primary Actor	DevSecOps Engineer / GitHub Actions
Preconditions	Developer pushes commit or opens pull request on GitHub repository.
Trigger	Automated GitHub Actions workflow triggered on push/PR to main branch.
Main Flow	1. Stage 1: Dependency scan via pip-audit & Safety. 2. Stage 2: SAST static code vulnerability analysis via Bandit (0 High/Medium alerts allowed). 3. Stage 3: Secret scanning via TruffleHog to detect API keys or certificates. 4. Stage 4: Unit, integration, and security test suites executed (pytest tests/security). 5. Stage 5: Container build & non-root verification. 6. Stage 6: DAST OWASP ZAP baseline vulnerability scan. 7. Pipeline marks build PASS or BLOCKS PR merge.
Exceptions	Bandit or Secret scanner flags violation -> Pipeline fails; PR blocked.
Postconditions	Zero known vulnerabilities or secrets reach production deployment.
Verification	SEC-TC-27, SEC-TC-28 (CI/CD GitHub Actions Workflow)